Security

The backend implements multiple layers of security to protect data and prevent abuse.

Authentication

JWT Bearer Tokens

- Users authenticate via `POST /api/auth/login`.
- The server issues a JWT signed with `JWT_SECRET`.
- Tokens are sent in the `Authorization` header: `Bearer <token>`.
- Tokens expire based on `JWT_EXPIRES_IN` (default: 7 days).

Password Hashing

- Passwords are hashed using `bcrypt` before storage.
- The `User` model stores only the hash, never the plaintext password.
- Login compares the provided password against the stored hash.

Session Management

- JWTs are stateless; no server-side session storage is required.

- The frontend stores the token in `localStorage`.
- On auth failure, the client removes the token and redirects to login.

Authorization

Role-Based Access Control

Role	Access
`user`	Public intake, knowledge base, status pages
`staff`	Ticket management, dashboard, knowledge base, users, departments
`admin`	Full access including settings, user CRUD, email templates, LDAP config

Route Protection

- `requireStaffOrAdmin` — Staff and admin access only.
- `requireAdmin` — Admin access only.
- Public routes are explicitly whitelisted.

Transport Security

CORS

- Origins are restricted to `CORS_ORIGINS` or `FRONTEND_URL`.
- Credentials are allowed for authenticated requests.
- In production, wildcard origins are rejected by `validateProductionConfig`.

Security Headers

Header	Value	Purpose
`X-Content-Type-Options`	`nosniff`	Prevent MIME type sniffing
`X-Frame-Options`	`DENY`	Prevent clickjacking
`Referrer-Policy`	`strict-origin-when-cross-origin`	Control referrer leakage
`Permissions-Policy`	`camera=(), microphone=(), geolocation=()`	Disable unnecessary browser features
`Cross-Origin-Resource-Policy`	`same-origin`	Prevent cross-origin reading
`Cache-Control`	`no-store`	Prevent caching of sensitive responses

Request Size Limits

- JSON body: 1mb (configurable via `JSON_BODY_LIMIT`)
- File uploads: 10mb (configurable via `MAX_FILE_SIZE`)

Input Validation

- Express JSON parser rejects malformed bodies.
- `express-validator` is available for route-level validation.
- Prisma parameterized queries prevent SQL injection.
- File type checking prevents malicious uploads.

Rate Limiting

Scope	Window	Max Requests
Global	15 min	600
Auth endpoints	15 min	30
Public ticket intake	15 min	30

Public API Protection

- `PUBLIC_TICKET_API_KEY` authenticates public ticket creation.
- `REQUIRE_PUBLIC_TICKET_API_KEY=true` enforces the check in production.
- The key is validated against the server configuration, not a database record.

Production Hardening

When `NODE_ENV=production`:

- CORS must use explicit HTTPS origins.
- `JWT_SECRET` must be at least 32 characters.
- `PUBLIC_TICKET_API_KEY` must be at least 32 characters.
- TLS is enforced for LDAP (`ldaps://`), SMTP, and IMAP.
- `x-powered-by` header is disabled.

Previous
« Services

Next
Scheduler »

GitHub

More

Deployment Guide

Troubleshooting

Copyright © 2026 KUCCPS. Built with Docusaurus.